Info Gathering

Telegram: @GitBook_s

- DNS
  - A Records
    - Nslookup
      - export TARGET="app.com"
      - nslookup $TARGET
    - dig
      - dig app.com @<nameserver/IP>
  - A Records for a Subdomain
    - Nslookup
      - export TARGET=sub.app.com
      - nslookup -query=A $TARGET
    - dig
      - dig a sub.app.com @<nameserver/IP>
  - PTR Records for an IP Address
    - Nslookup
      - nslookup -query=PTR <ip address>
    - dig
      - dig -x <ip address> @<nameserver/IP>
  - ANY Existing Records
    - Nslookup
      - export TARGET="app.com"
      - nslookup -query=ANY $TARGET
    - dig
      - dig any app.com @<nameserver/IP>
  - TXT Records
    - Nslookup
      - export TARGET="app.com"
      - nslookup -query=TXT $TARGET
    - dig
      - dig txt app.com @<nameserver/IP>
  - MX Records
    - Nslookup
      - export TARGET="app.com"
      - nslookup -query=MX $TARGET
    - dig
      - dig mx app.com @<nameserver/IP>
- WHOIS
  - Online
    - https://whois.domaintools.com/
  - Linux
    - export TARGET="app.com"
    - whois $TARGET
  - Windows
    - whois.exe app.com
- Subdomain
  - PASSIVE
    - VirusTotal
      - "Relations" tab
    - Certificates
      - Online
        - https://censys.io
        - https://crt.sh/
      - Command Line
        - export TARGET="app.com"
        - curl -s "https://crt.sh/?q=${TARGET}&output=json" | jq -r '.[] | "\(.name_value)\n\(.common_name)"' | sort -u > "${TARGET}_crt.sh.txt"
        - head -n20 app.com_crt.sh.txt
    - Automation
      - TheHarvester
        - gathering information from sources
          - export TARGET="facebook.com"
          - cat sources.txt | while read source; do theHarvester -d "${TARGET}" -b $source -f "${source}_${TARGET}";done
        - extract all the subdomains found and sort them
          - cat *.json | jq -r '.hosts[]' 2>/dev/null | cut -d':' -f 1 | sort -u > "${TARGET}_theHarvester.txt"
        - merge all the passive reconnaissance files
          - cat facebook.com_*.txt | sort -u > facebook.com_subdomains_passive.txt
          - cat facebook.com_subdomains_passive.txt | wc -l
  - ACTIVE
    - ZoneTransfers
      - Online
        - https://hackertarget.com/zone-transfer/
      - Command Line
        - Identifying Nameservers
          - nslookup -type=NS <domain name>
        - Testing for ANY and AXFR Zone Transfer
          - nslookup -type=any -query=AXFR <domain name> <subdomain>
    - Gobuster
      - export TARGET="facebook.com"
      - export NS="d.ns.facebook.com"
      - export WORDLIST="numbers.txt"
      - gobuster dns -q -r "${NS}" -d "${TARGET}" -w "${WORDLIST}" -p ./patterns.txt -o "gobuster_${TARGET}.txt"
- Infrastructure
  - PASSIVE
    - Netcraft
      - https://sitereport.netcraft.com
    - Wayback Machine
      - http://web.archive.org/
      - waybackurls
        - waybackurls -dates https://facebook.com > waybackurls.txt
        - cat waybackurls.txt
  - ACTIVE
    - HTTP Headers
      - identify the webserver version
      - curl -I http://${TARGET}
    - WhatWeb tool
      - recognizes web technologies
      - whatweb -a3 https://www.facebook.com -v
    - Wappalyzer
      - what websites built with
      - https://www.wappalyzer.com/
    - WafW00f Tool
      - sends requests and analyses responses to determine if a security solution is in place
      - -a to check all possible WAFs in place instead of stopping scanning at the first match
      - -i flag to read targets from an input file
      - -p option to proxy the requests
      - wafw00f -v https://www.tesla.com
    - Aquatone Tool
      - overview of HTTP-based attack surfaces
      - taking screenshots
      - cat facebook_aquatone.txt | aquatone -out ./aquatone -screenshot-timeout 1000
      - the result in: a file called aquatone_report.html
- VHost
  - test some subdomains having the same IP address that can either be virtual hosts or different servers
  - Manual
    - if identified a web server
      - make a cURL request sending a domain previously identified
      - vHost Fuzzing using a dictionary file of possible vhost names
        - cat /opt/useful/SecLists/Discovery/DNS/namelist.txt | while read vhost;do echo "\n********\nFUZZING: ${vhost}\n********";curl -s -I http://targetIP -H "HOST: ${vhost}.randomtarget.com" | grep "Content-Length: ";done
      - if successfully identified a virtual host
        - curl -s http://targetIP -H "Host: vhost.randomtarget.com"
  - Automatic
    - Using ffuf
      - ffuf -w /opt/useful/SecLists/Discovery/DNS/namelist.txt -u http://targetIP -H "HOST: FUZZ.randomtarget.com" -fs xxx
- Crawling
  - find as many pages and subdirectories belonging to a website
    - Using ZAP
      - built-in Fuzzer and Manual Request Editor
        - Write the website in the address bar and add it to the scope
        - then use the Spider submenu
    - Using FFuF
      - -recursion: Activates the recursive scan.
      - -recursion-depth: Specifies the maximum depth to scan.
      - -u: Our target URL, and FUZZ will be the injection point.
      - -w: Path to our wordlist.
      - ffuf -recursion -recursion-depth 1 -u http://targetIP/FUZZ -w /opt/useful/SecLists/Discovery/Web-Content/raft-small-directories-lowercase.txt
    - Sensitive Information Disclosure
      - find backup or unreferenced files that can have important information or credentials.
        - create a file with the found folder names
          - folders.txt
        - using CeWL to extract some keywords from the website
          - instruct tool with minimum length ex of 5 characters -m5, convert them to lowercase --lowercase
          - cewl -m5 --lowercase -w wordlist.txt http://targetIP
        - combine everything in ffuf
          - ffuf -w ./folders.txt:FOLDERS,./wordlist.txt:WORDLIST,./extensions.txt:EXTENSIONS -u http://192.168.10.10/FOLDERS/WORDLISTEXTENSIONS
          - ```
            [Status: 200, Size: 8, Words: 1, Lines: 2]
                * EXTENSIONS: ~
                * FOLDERS: wp-content
                * WORDLIST: secret
            ```
          - ex: curl http://targetIP/wp-content/secret~
            ```